

AI Incident Response Playbook

1. Executive Summary & Purpose

This playbook outlines the standard operational procedures for identifying, responding to, containing, and recovering from artificial intelligence and machine learning security incidents. As AI systems are integrated into critical workflows, they introduce unique vulnerabilities, including prompt injection, model inversion, membership inference, training data poisoning, and model evasion. The goal of this document is to minimize operational downtime, protect proprietary intellectual property, ensure compliance with global AI safety regulations, and preserve customer trust.

2. Classification of AI Security Incidents

Incidents are categorized into four severity tiers based on their business impact and security risk:

- Severity Level 1 (Critical): Active model exploitation resulting in unauthorized exfiltration of customer PII, systemic generation of toxic or malicious payloads in customer-facing production channels, or complete disruption of core machine learning inference endpoints.
- Severity Level 2 (High): Model manipulation via prompt injection that bypasses system guardrails but remains contained within sandbox environments, or moderate drift in model prediction outputs indicating potential training dataset contamination.
- Severity Level 3 (Medium): Sporadic API errors, minor drift in recommendation system performance metrics, or low-risk data ingestion anomalies.
- Severity Level 4 (Low): General inquiries regarding AI behaviors, system configuration tuning requests, or normal deviations in model latency.

3. Incident Containment & Mitigation Procedures

Upon confirmation of an active exploit or high-severity anomaly, the AI Incident Response Team must execute the following containment measures immediately:

- Step 3.1: Isolate affected model inference endpoints. Route incoming traffic to fallback heuristic models or static explanation pages to prevent further exploitation.
- Step 3.2: Capture and freeze state. Take snapshots of model weights, current context window buffers, API request logs, and data pipelines for forensic examination.
- Step 3.3: Re-evaluate safety guardrails. Update the input-output validation layers (e.g., Llama Guard, NeMo Guardrails) to filter the specific payload strings or attack patterns observed.
- Step 3.4: Revert to the last known secure model version. If the active model exhibits systemic instability or weights have been modified, deploy the backup container from the secure repository.

4. Recovery and Post-Incident Forensic Auditing

After containment is successful, system restoration can begin. The AI engineering team must audit all training pipelines to identify the vulnerability vector. If the root cause was data poisoning, the contaminated dataset must be isolated and rebuilt. All logs during the incident window must be ingested into the observability stack (e.g., Loki and Prometheus) to refine automated detection rules for prompt injections or evasions. Finally, a structured Post-Incident Report (PIR) detailing the root cause, financial impact, response duration, and preventative action items must be submitted to the Risk Management Committee within 48 hours.